

Security Testing Analysis Report

Name : Muhammad Maisam Raza

Reg no : 2023463

Overview

As requested, the three security testing steps were performed on the Deliverable 2/server directory. Below are the details and results of each test.

Test 1: Standard `npm audit`

Command Executed:

```
npm audit
```

Result: The audit completed successfully and identified a total of 1 vulnerability in the dependencies. The overall health is good, with no severe issues detected.

Test 2: JSON Export (`npm audit --json`)

Command Executed:

```
npm audit --json > "../../Deliverable-3/01 Security Testing Analysis/npm-audit.json"
```

Result: The detailed audit output was successfully exported to the specified JSON file. The JSON file contains the full vulnerability report, including metadata, dependency paths, and remediation instructions.

Test 3: HIGH/CRITICAL Vulnerabilities Check

Objective: Note any HIGH or CRITICAL vulnerabilities. **Result:**

- CRITICAL Vulnerabilities: 0
- HIGH Vulnerabilities: 0
- MODERATE Vulnerabilities: 1
- LOW Vulnerabilities: 0

Conclusion on HIGH/CRITICAL: There are **NO** High or Critical vulnerabilities present in the `server` dependencies.

Detailed Findings (Moderate Issue)

The only vulnerability found is of **moderate** severity:

- Package:** `uuid` (Version `<14.0.0`)
- Issue:** Missing buffer bounds check in `v3/v5/v6` when `buf` is provided.
- Reference:** [GHSA-w5hq-g745-h8pq](#)
- Remediation:** This can be fixed via `npm audit fix --force`, which will update `uuid` to `@14.0.0` (Note: this is a breaking change).

Test 4 (T8): Encryption at Rest – Complaint Data in Database

Objective: Submit a complaint containing plain text and verify that the stored record in the database is NOT human-readable (i.e., encrypted).

Procedure

- Logged into the ESCMS application as a student user (`test_student`).
- Navigated to **Submit Complaint** page.
- Submitted a complaint with:
 - Title:** `this is a test complaint`
 - Description:** `this is a test complaint description for security testing`
 - Category:** `Harassment`
 - Priority:** `Medium`
- Opened the raw SQLite database (`server/data/escms.db`) and ran a direct SQL query:

```
SELECT id, title_enc, description_enc, category, status FROM complaints ORDER BY id DESC LIMIT 1;
```

Raw Database Record

Field	Stored Value
id	1
title_enc	d0e3ad94371e38e3dc909930d5d1027a:3cac9828c2d1a7dc752510444732ccd6:bae2b436fb3c167b2896c0c87b59b70f4f234aa5de264c71
description_enc	60f4bdc06827e7c3ea649ec0b0528ad6:05308aeec8f22eade082e6d04d31c2ea:9da9ac3e17ff18b5527d8b4f2c978d72e7a8782cd3c7d7df44669fb739c1f32f829b5537270c9de17cd982990054412258905997448737cf13
category	Harassment
status	submitted

Analysis

- The plaintext submitted was: **"this is a test complaint"**
- The value stored in `title_enc` is: `d0e3ad94371e38e3...` – a hex-encoded `iv:authTag:ciphertext` string (AES-256-GCM format).
- The complaint text is **NOT human-readable** in the database. ☹️
- Encryption algorithm used: **AES-256-GCM** with random 16-byte IV and 16-byte authentication tag per record.

Result: ☑️ **PASS** – Complaint data confirmed encrypted in DB

Test 5 (T7): Session Invalidation After Logout

Objective: Log in, copy the session cookie, log out, then replay the old cookie to access a protected endpoint. The old session should be rejected.

Procedure

- Logged in** as `admin` (username: `admin`, password: `Admin@12345`).
 - Server responded: `200 OK` – `"Login successful."`
- Verified session is active** by calling `GET /api/auth/me`.
 - Server responded: `200 OK` – returned user details for `System Administrator`.

3. Saved the session cookie value:

```
escms.sid = s%3AL0ntrEYiDpqrKbP1qCrGMDFrThM6PRyS.LYH...
```

4. Logged out by calling POST /api/auth/logout .
- Server responded: 200 OK – "Logged out successfully."
5. Replayed the old session cookie by manually attaching the saved escms.sid cookie and calling GET /api/auth/me .
- Server responded: 401 Unauthorized – "Authentication required. Please log in."

Evidence

```
[Before Logout] GET /api/auth/me → 200 OK (session valid)
[After Logout] GET /api/auth/me → 401 Unauthorized (old cookie rejected 🚫)
```

Analysis

- The server calls req.session.destroy() on logout, which invalidates the session in the server-side session store.
- The cookie escms.sid is also cleared via res.clearCookie('escms.sid') .
- Even when the old cookie is manually re-attached, the server correctly rejects it because the session no longer exists server-side.

Result: 🟢 PASS – Old session cookie rejected after logout

Overall Summary

Test	Description	Result
T1	npm audit	🟢 PASS
T2	npm audit --json export	🟢 PASS
T3	HIGH/CRITICAL vulnerability check	🟢 PASS (0 found)
T8	Encryption at rest (complaint data)	🟢 PASS
T7	Session invalidation after logout	🟢 PASS

All five security tests have been successfully performed and passed.